INTERNET-OF-THINGS:

SURVIVING THE CHAOS BY EXPECTING IT

UPDATE 2021
J.P. DIAS
11/FEB/2021

whoami

- From Porto, PT

- Invited Assistant Lecturer @FEUP
- Researcher @FEUP & @INESCTEC
- PhD Student @ProDEI@FEUP

- http://jpdias.me
- jpmdias@fe.up.pt || jpdias@pm.me
- @jpd1as

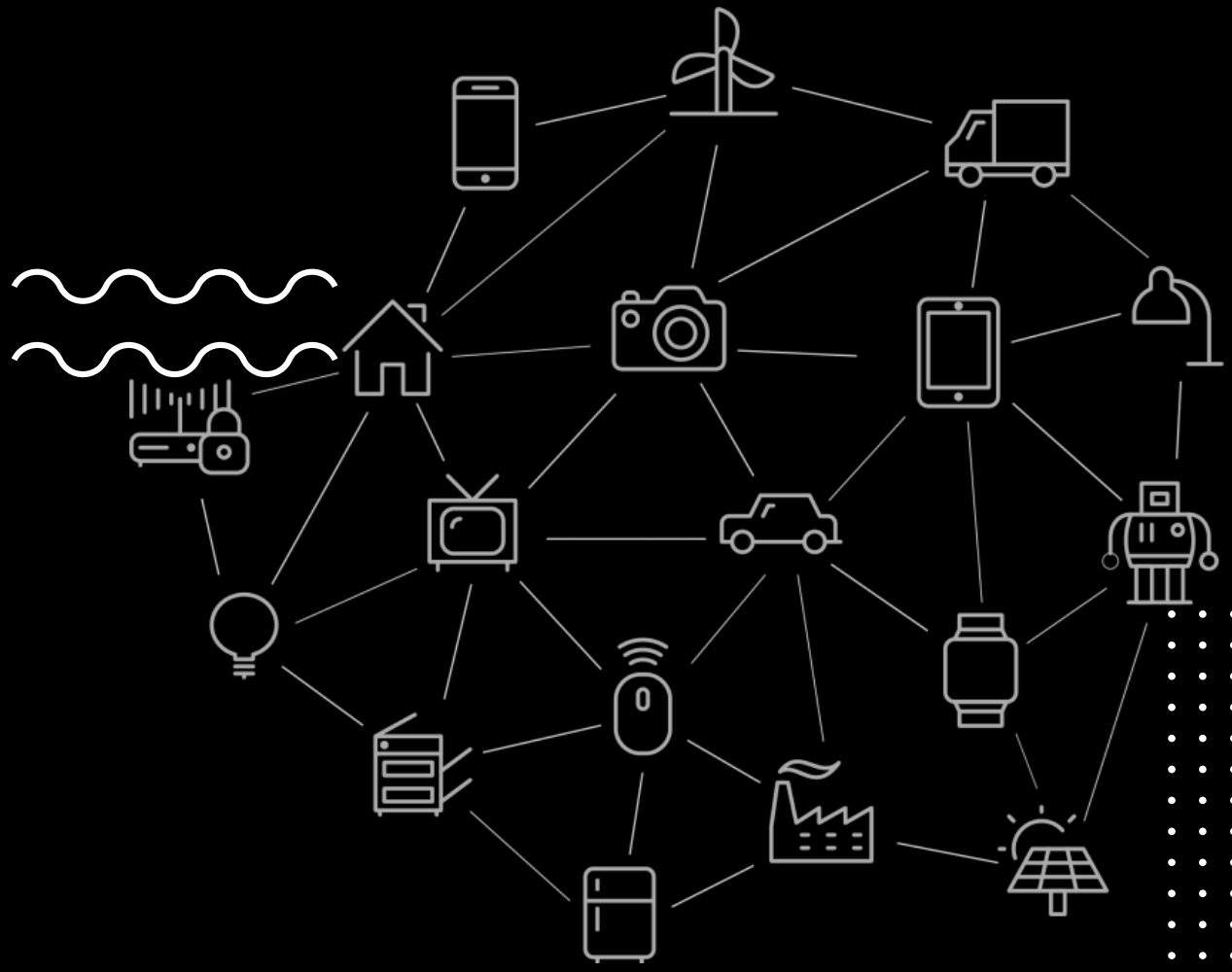
- Keywords:
  - Internet-of-Things
  - Software Engineering
  - Security & Privacy

  - Hardware / Software Hacking
  - Software-Defined Radio
  - Retro-computing
  - Photography
  - *insert shinny new thing*

Agenda

1. Internet-of-Things: *What*? *How*? *Who*?
2. The Chaos of the Untamed Fragmentation
3. Surviving the Outbreak
4. Thoughts on the Fallout
5. Ongoing Research

Internet-of-Things



What?

- “(…) natural **evolution of the Internet** including not only the **communication** between humans but also **with any kind of object**.”

Hardion et al., The Internet of Things and Control Systems

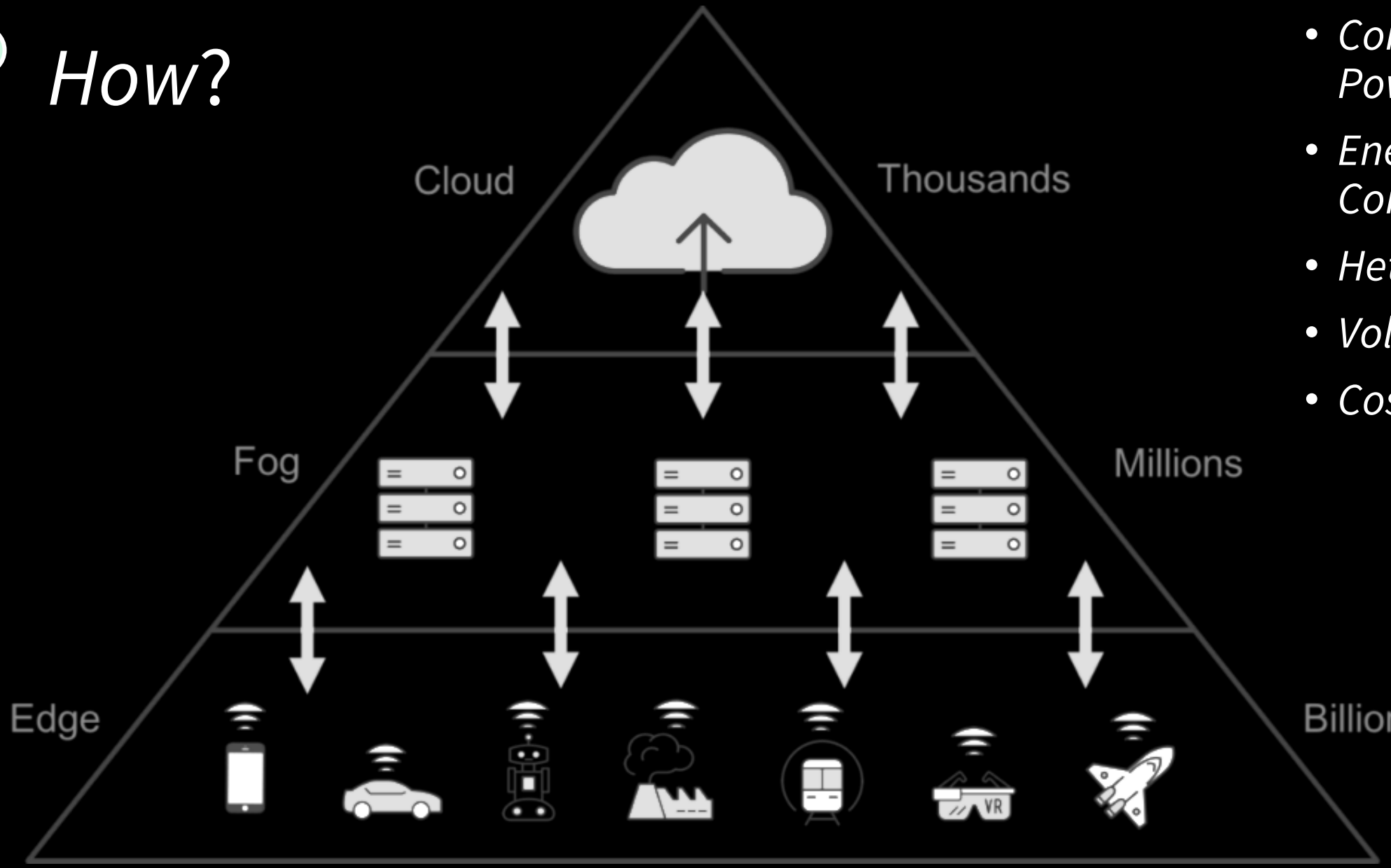
- “(…) **distributes computational devices massively in almost any axis imaginable** and **connects them intimately to previously non-cyber aspects of human life**.”

Sean Smith, The Internet of Risky Things

- “Interconnection of **sensing and actuating devices** providing the ability to share information across platforms (…). This is achieved **by seamless large-scale sensing**, **data analytics** and **information representation** using cutting edge **ubiquitous sensing** and **cloud computing**.”

Gubbi et al., Internet of Things (IoT): A Vision, Architectural Elements, and Future Directions

How?

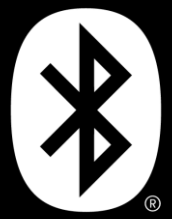


- *Computing Power*
- *Energy Consumption*
- *Heterogeneity*
- *Volatility*
- *Cost*

How? Communications









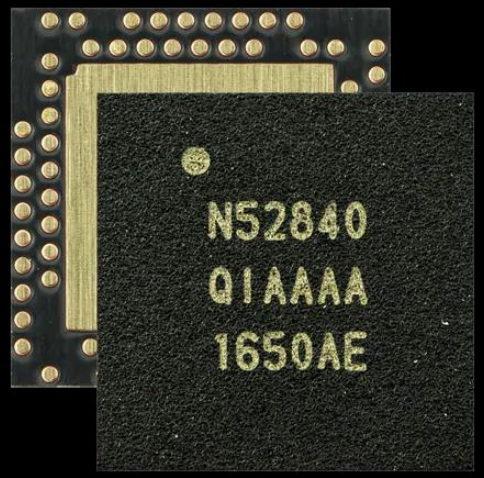




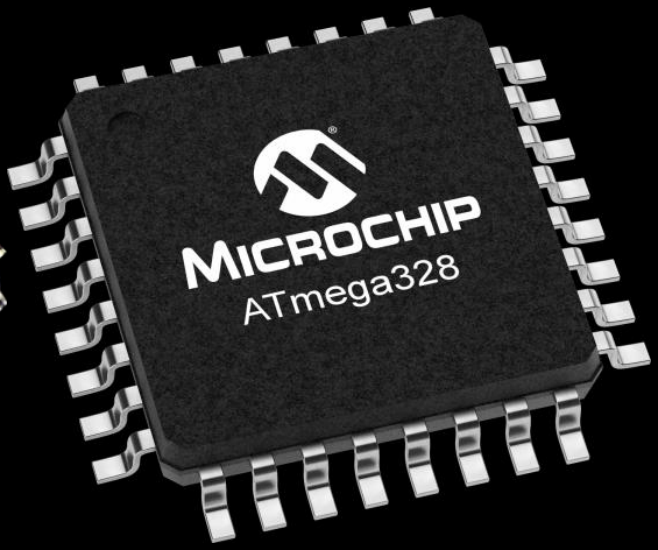


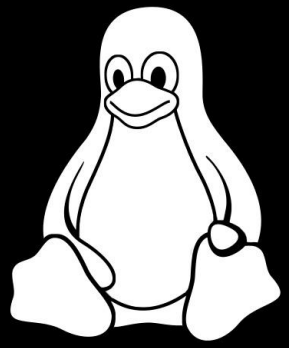
How? Devices & OS

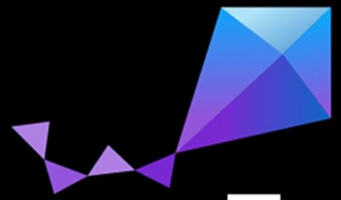












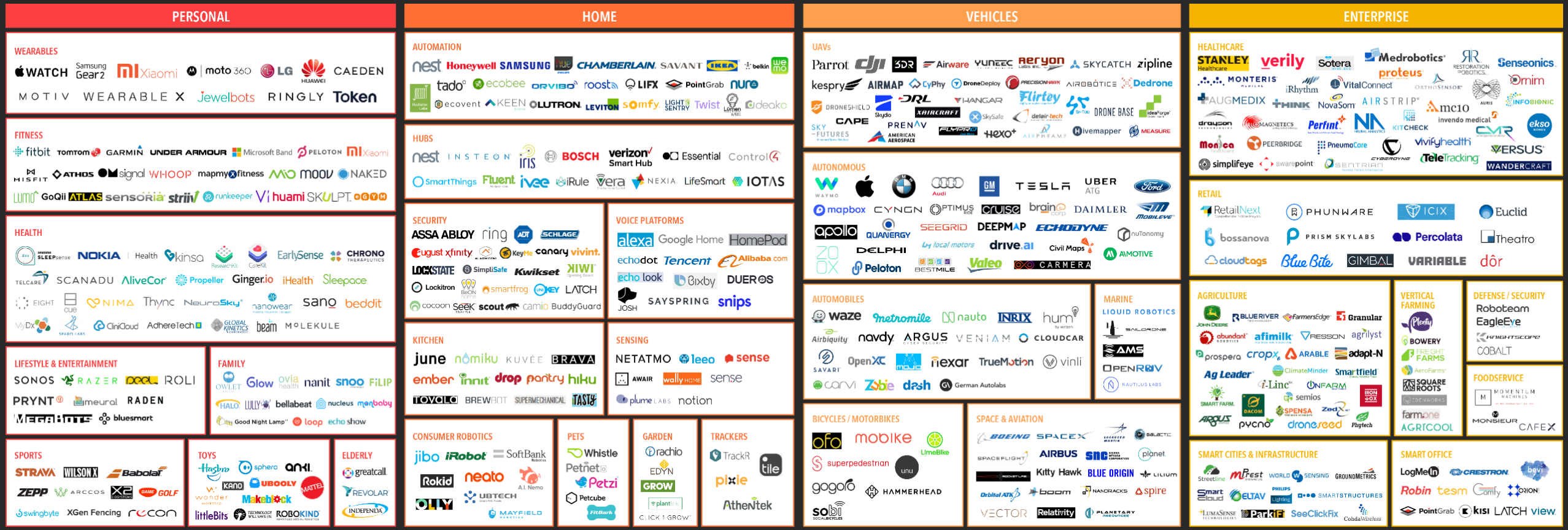
Zephyr™

amazon

freeRTOS

ARDUINO™

Who? The vertical silos

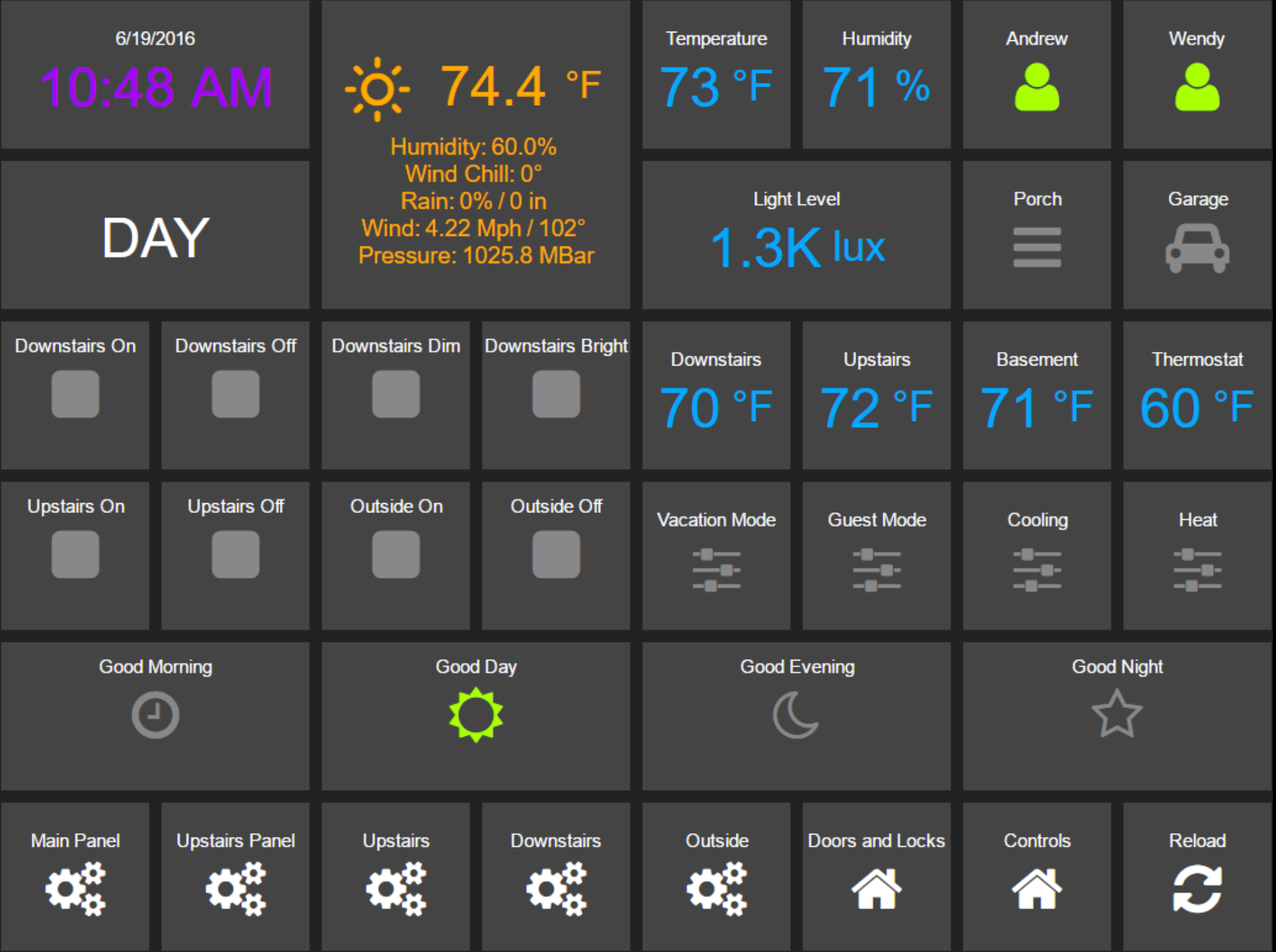


© Matt Turck (@mattturck), Demi Obayomi (@demi_obayomi) & FirstMark Capital (@firstmarkcap)

Final version, revised and updated as of February 7, 2018

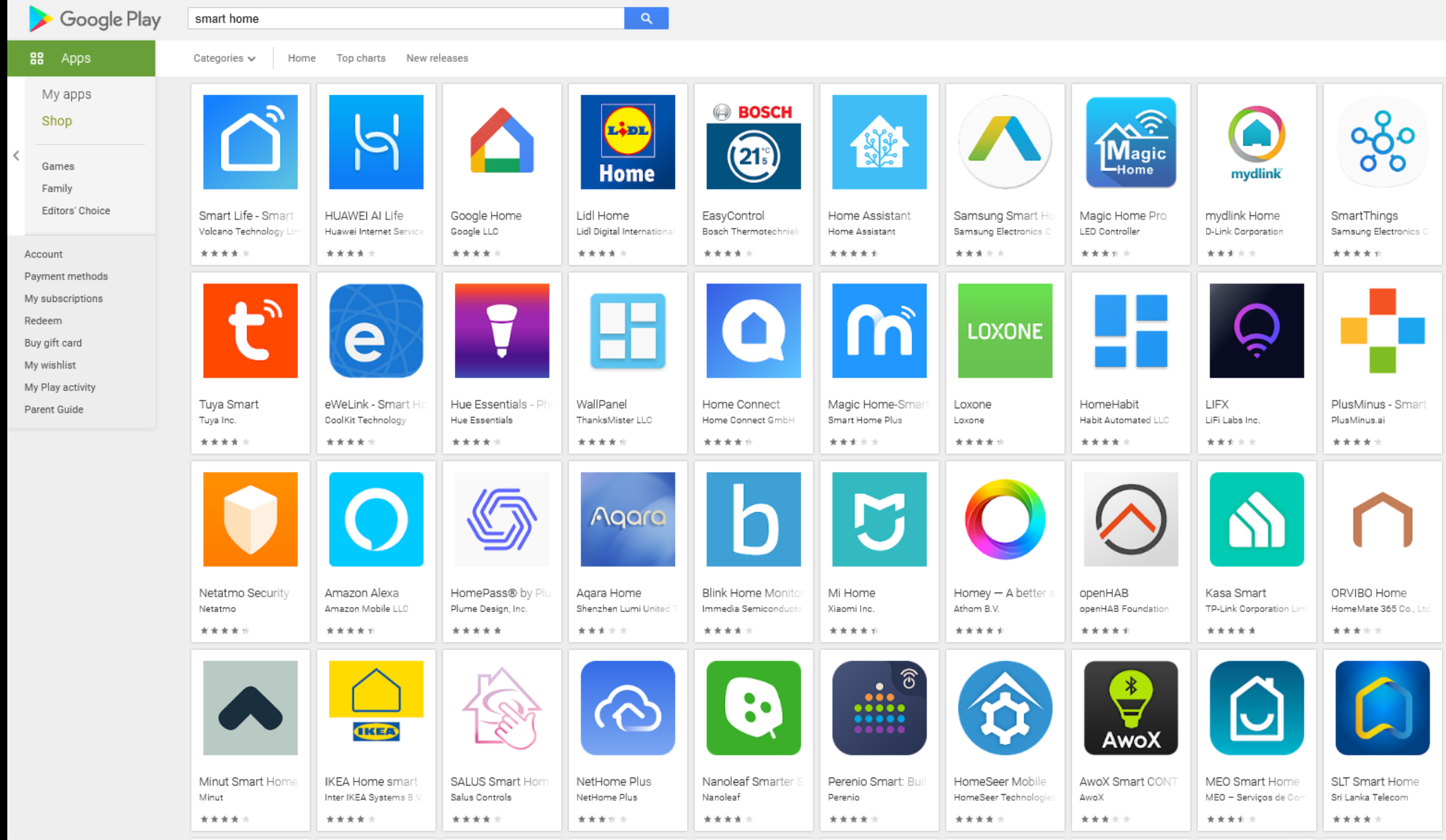
FIRSTMARK
EARLY STAGE VENTURE CAPITAL

THE CHAOS OF THE UNTAMED FRAGMENTATION



What IoT should be like…

What IoT is…


Google Play
smart home
Apps
My apps
Shop
Games
Family
Editors' Choice
Account
Payment methods
My subscriptions
Redeem
Buy gift card
My wishlist
My Play activity
Parent Guide
Categories
Home
Top charts
New releases
Smart Life - Smart
HUAWEI AI Life
Google Home
Lidl Home
EasyControl
Home Assistant
Samsung Smart Ho
Magic Home Pro
mydlink Home
SmartThings
Tuya Smart
eWeLink - Smart Ho
Hue Essentials - Phi
WallPanel
Home Connect
Magic Home-Smart
Loxone
HomeHabit
LIFX
PlusMinus - Smart
Netatmo Security
Amazon Alexa
HomePass® by Plu
Aqara Home
Blink Home Monito
Mi Home
Homey — A better s
openHAB
Kasa Smart
ORVIBO Home
Minut Smart Home
IKEA Home smart
SALUS Smart Hom
NetHome Plus
Nanoleaf Smarter S
Perenio Smart: Buil
HomeSeer Mobile
AwoX Smart CONT
MEO Smart Home
SLT Smart Home

Cloud-First, Cloud-Only, Local-First, Local-Only…

- “The paradigm of cloud computing has transformed the IT industry, enabling developers to use high-performance hardware and applications (…) with significant reductions in hardware maintenance costs, scalability, and so forth.”

- “The ability to **offload complex tasks from devices with limited computation capabilities to virtually limitless processing capacity in the cloud** (…) ignores two major issues: **threats to privacy** from organizational and government surveillance, and **advances in hardware capabilities**.”

Rawassizadeh et al., NoCloud: Exploring Network Disconnection through On-Device Data Analysis

The Cloud/Internet Dependency

NEWS

Home | Coronavirus | Video | World | UK | Business | Tech | Science | Stories | Entertainment & Arts | Health

Tech

AWS: Amazon web outage breaks vacuums and doorbells

26 November 2020

IoT company bricks customer's device after negative review



by **Conner Forrest** in **Security** on April 5, 2017, 12:43 PM PST

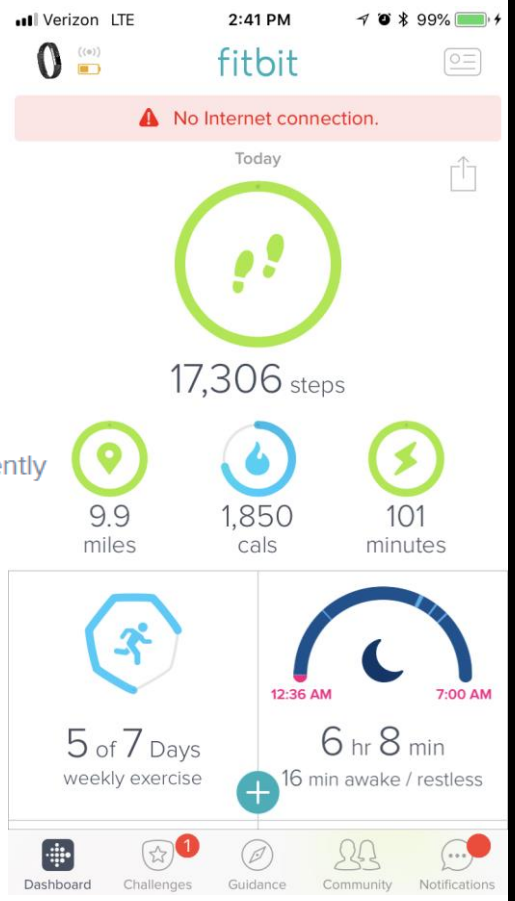
Garadget, which offers an internet-connected garage door opener, recently denied a customer access to its server after he left a negative review.

Technology Intelligence

'Smart' home devices stop working after European data law comes into force

People in Europe who use internet-connected lightbulbs from Chinese technology company Yeelight found themselves unable to turn their lights on or off from their smartphones on Friday.

"According to GDPR, we will not be able to continue to provide this service to you," Yeelight's app read when customers tried to use the smartbulbs.



The *S* in IoT stands for Security

- Will embedded machines be patchable?
- Will anyone think of maintaining the inexpensive parts of the physical infrastructure?
- Will machines and software last longer than the IoT startups that create them?
- Will anyone even remember where the machines are?

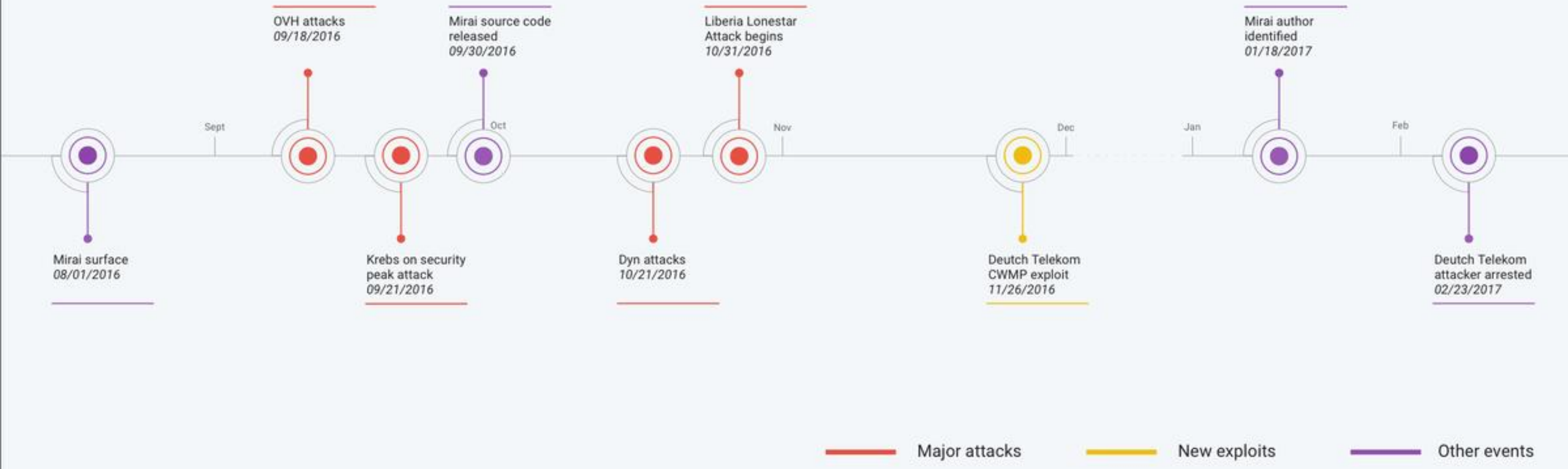
- When the inevitable happens, **what will a compromised machine in the IoT be able to do**?

It’s no longer just containing data; it’s controlling boiler temperatures, elevator movement, automobile speed, fish tank filters, and insulin pumps…

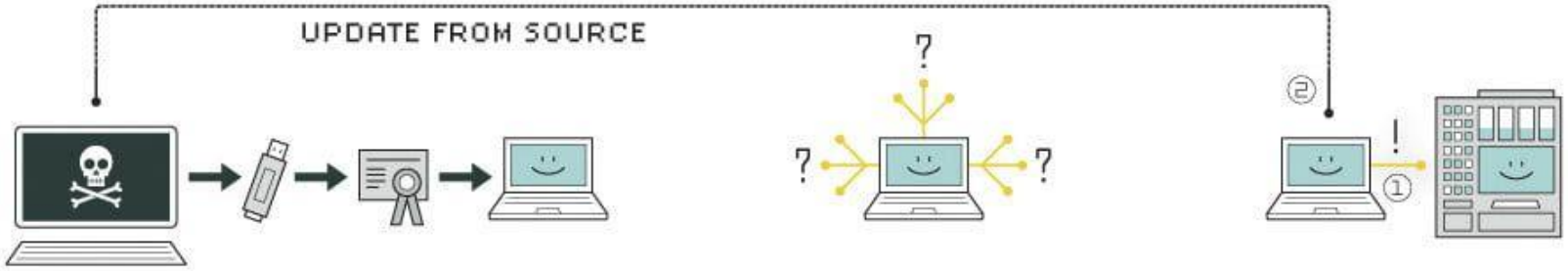
Sean Smith, The Internet of Risky Things

Mirai major event timeline

https://elie.net/mirai



A view on Stuxnet



1. infection
Stuxnet enters a system via a USB stick and proceeds to infect all machines running Microsoft Windows. By brandishing a digital certificate that seems to show that it comes from a reliable company, the worm is able to evade automated-detection systems.

2. search
Stuxnet then checks whether a given machine is part of the targeted industrial control system made by Siemens. Such systems are deployed in Iran to run high-speed centrifuges that help to enrich nuclear fuel.

3. update
If the system isn't a target, Stuxnet does nothing; if it is, the worm attempts to access the Internet and download a more recent version of itself.



4. compromise
The worm then compromises the target system's logic controllers, exploiting "zero day" vulnerabilities-software weaknesses that haven't been identified by security experts.

5. control
In the beginning, Stuxnet spies on the operations of the targeted system. Then it uses the information it has gathered to take control of the centrifuges, making them spin themselves to failure.

6. deceive and destroy
Meanwhile, it provides false feedback to outside controllers, ensuring that they won't know what's going wrong until it's too late to do anything about it.

This device is now deprecated ™

engadget

Reviews Gear Gaming Entertainment Products Tomorrow Audio Video Deals Buyer's Guide

Google's Android Things platform will shut down in a little over a year

It's shutting down Android Things on January 5th, 2022.

Home > Products > What will happen when the IoT reaches its end of life?

IOT

What will happen when the IoT reaches its end of life?

Any product has a limited lifespan, determined either by its purpose, parts or the manufacturer. In the past, a product may have been repaired/replaced in the event of a fault but was otherwise unsupported. With the Internet of Things (IoT) the role of the manufacturer is metamorphosising.

By Ken Munro, Partner, Pen Test Partners

STREAMING

These Sonos Products Will Stop Receiving Updates in May



Brendan Hesse
1/21/20 1:00PM

The Privacy-scandal

- Identification
- Localization and Tracking
- Profiling
- Privacy-violating interaction and presentation
- Lifecycle transitions
- Inventory attack
- Linkage

Ziegeldorf et al., Privacy in the Internet of Things: Threats and Challenges

Who owns your data?

- “The analyzed **metadata** revealed even more how deep smart speakers intrude your private sphere – and that in the end Amazon, Apple and Google will know (nearly) everything about you. ”

@sveckert, Alexa, who else is listening?, https://media.ccc.de/v/rc3-466940-alexa_who_else_is_listening

Thousands Of Banned Chinese Surveillance Cameras Are Watching Over America



Thomas Brewster Forbes Staff

Cybersecurity

Associate editor at Forbes, covering cybercrime, privacy, security and surveillance.

Who controls Huawei? Chinese telecoms leader’s ownership structure explained in more detail

- Huawei goes on the offensive after research paper questions ownership structure

Your smart light bulb might be sending your data to China

Apps connected to smart light bulbs sold in Walmart and Best Buy are communicating with Chinese servers, report says

Topic | Cybersecurity



Masha Borak

Published: 7:01pm, 1 Mar, 2019

DAVID NIELD GEAR 01.13.2021 08:00 AM

How Amazon Sidewalk Works—and Why You May Want to Turn It Off

The premise is convenient. But the ecommerce giant’s record on privacy isn’t exactly inspiring.

The Quest for Reliability

- **Device reliability**: battery-dependency, memory and CPU constraints, harsh environmental conditions and “fail-dirty” sensors.
- **Communication and network reliability:** identification and mobility, addressing too many devices (is this the year of IPv6?), interferences (…) network is liable to drop sensor readings, or produce unreliable readings.
- **Application layer reliability:** “If anomalous data is sent from the device through the network into the application layer, this will reduce the reliability of the application.”

Moore et al., IoT reliability: a review leading to 5 key research directions

THE RISKS DIGEST

Forum on Risks to the Public in Computers and Related Systems

ACM Committee on Computers and Public Policy, Peter G. Neumann, moderator

Thermostat failure mode

<bukys@cs.rochester.edu>

Mon, 14 Oct 91 12:05:48 EDT

I have a typical electronic setback thermostat installed. A couple of nights ago it failed "on", causing my furnace to run and run, until my three-year-old woke up and came to tell me that she was hot. The temperature had reached 92 degrees(F).

The thermostat itself had decided that it was still 68 degrees(F). Rebooting the thermostat by removing and re-inserting the batteries made it get back in touch with reality. I replaced the batteries too, but, considering it had enough power to run the LCDs, that's probably not it.

Surviving the Outbreak

Offline-first & Local-first

- “We can’t keep building apps with the desktop mindset of permanent, fast connectivity, where a **temporary disconnection or slow service is regarded as a problem and communicated as an error**.”

  Offline First, http://offlinefirst.org/

- “Cloud apps are popular because they **enable real-time collaboration**, and **make it easy for us to access our work from all of our devices**. However, by **centralizing data storage on servers, cloud apps also take away ownership and agency from users**. If a service shuts down, the software stops functioning, and data created with that software is lost.

  Kleppmann et al., Local-first software: you own your data, in spite of the cloud

Ownership *vs* Features

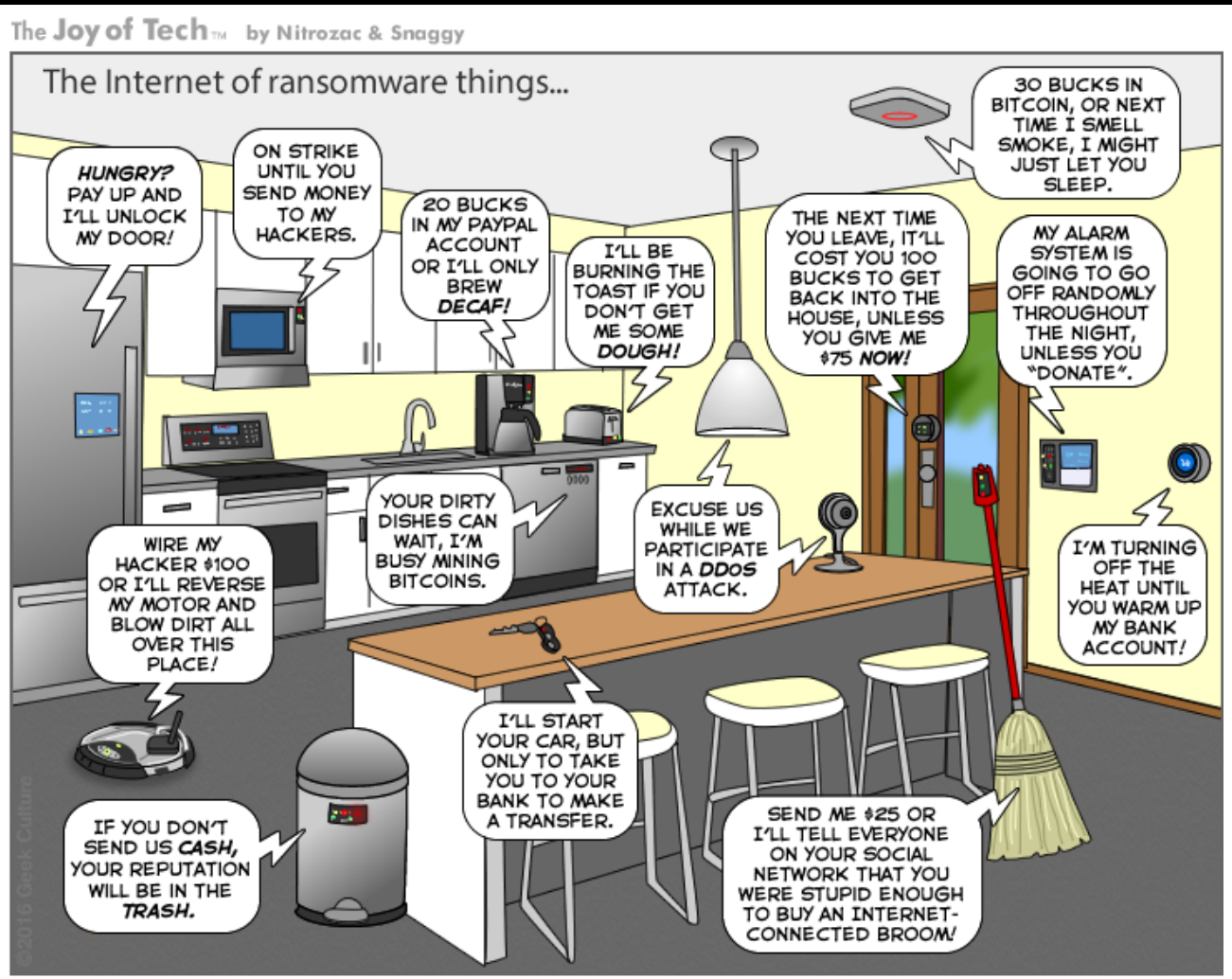
- Manual configuration (and program) *vs* Plug-and-play experience.
- No “catch-all” voice interaction *vs* Easy integration with Smart Assistants.
- Devices’ (vendors) limitations on manual configuration and DIY integrations.
- Build-your-own-system requires some degree of technical knowledge.

Internet-of-broken-Things -- A highly-opinionated overview (0xOPOSEC), https://speakerdeck.com/jpdias/internet-of-broken-things

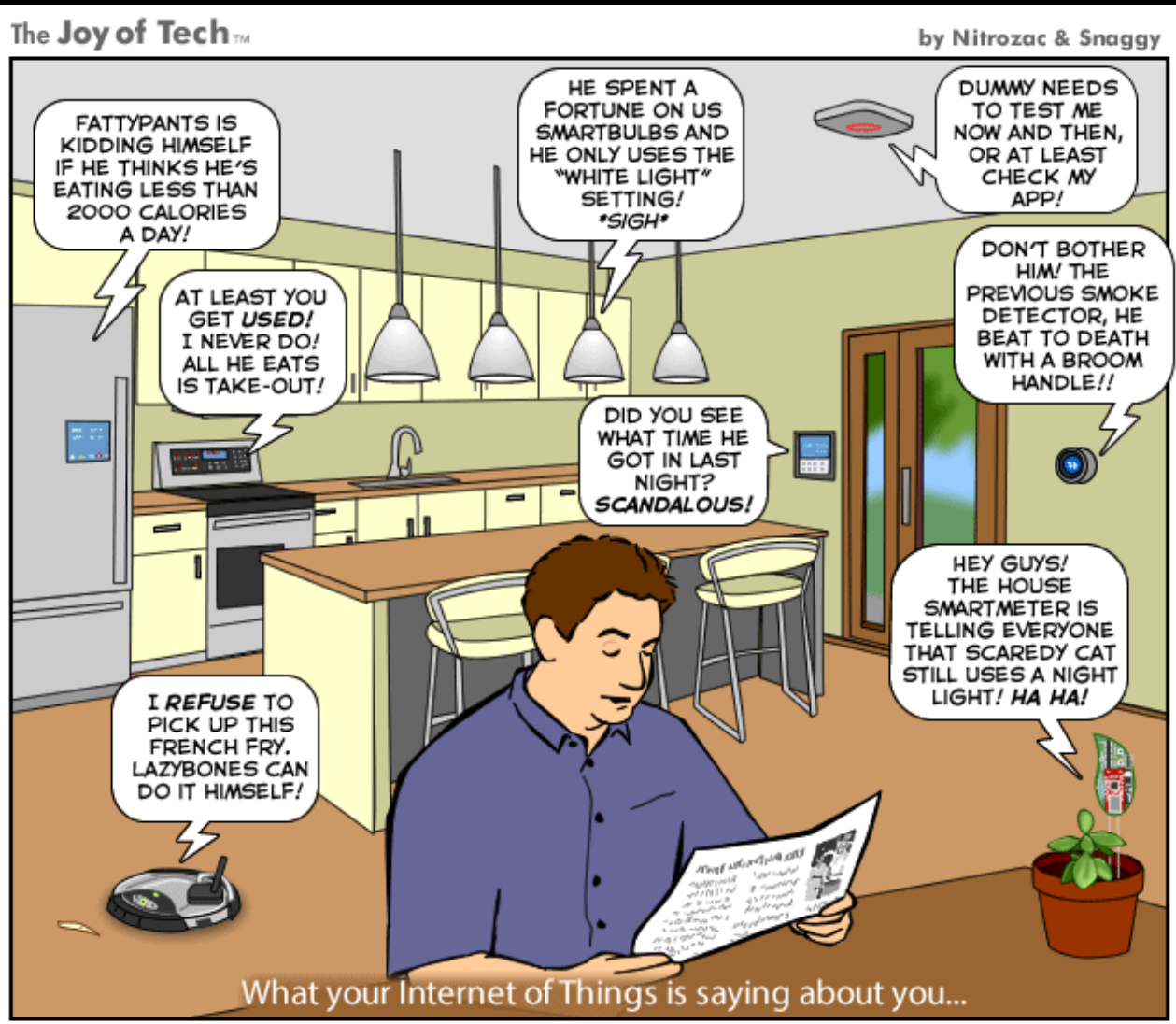
- Carefully **analyze the devices before buying them**.
- Always **prefer devices** and systems **that work** out-of-the-box **without Internet** connection (not even for “installation”).
- Create a **segregated VLAN only for the IoT devices** if it’s possible.
- **Avoid devices that use** “unknown” or **proprietary** protocols.

Reliability

- Always think on the **worst scenario** that could happen:
  - What if I lose Internet connection?
  - What if an attacker gains access to my home network?
  - What if there’s a sudden power loss (or spike)?
  - What if the communication gateway (or router) disappears?
  - What if a sensor reports erroneous readings?
  - What if an actuator goes rogue (e.g. an out-of-control Roomba)?



You can help us keep the comics coming by becoming a patron!
www.patreon/joyoftech



THOUGHTS ON THE FALLOUT



Security-wise

- “If we build this new internet the way we built the current Internet of Computers (IoC), we are heading for trouble: **humans cannot effectively reason about security when devices become too long- lived, too cheap, too tightly tied to physical life, too invisible, and too many**.”

Sean Smith, The Internet of Risky Things

Regulamentation and Certification

- General lack of regulamentation (GDPR was a good start).
- Adjustment of Certification beyond RF emissions and power loads.

- But, typically, legislation is too slow-paced when compared to technological evolution.

The Path to Idiot Proof Systems

- “Programming today is **a race between software engineers** striving to build bigger and **better idiot-proof programs**, and the **Universe trying to produce bigger and better idiots**. So far, the Universe is winning.”

Rick Cook, The Wizardry Compiled

Self-Managed Systems & Autonomic Computing

- Inspired in the autonomic nervous system of the human body, IBM Research introduced the concept of **autonomic computing**.

- Progressively make computing systems **more self-managed**, **hiding the intrinsic complexity of the systems** away from operators and other users.
- Systems should also be **capable of adapting to unpredictable changes in its operational environment** while increasing predictability, speed of response, and reliability of computing systems.

- On April 26, 1986, the Number Four RBMK reactor at the nuclear power plant at Chernobyl, Ukraine, went out of control during a test at low-power (…).
- Safety measures were ignored, the uranium fuel in the reactor overheated and melted through the protective barriers.





Launched in 1977, “*Voyager 2 has returned to normal operations following the anomaly on Jan. 25, 2020. The five operating science instruments, which were turned off by the spacecraft's* ***fault protection routine****, are back on and returning normal science data.*”

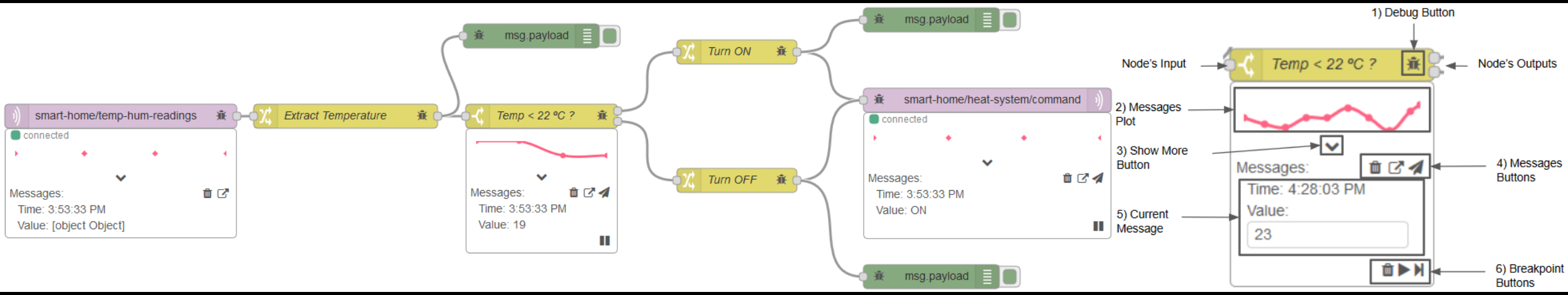
“(…) unexplained delay in the onboard execution of the maneuver commands inadvertently left two systems that consume relatively high levels of power operating at the same time. This caused the spacecraft to **overdraw its available power supply**.”

“The fault protection software routine was designed to **automatically manage such an event, and by design, it appears to have turned off Voyager 2's science instruments** to make up for the power deficit.”

Voyager 2 Returns to Normal Operations,
https://www.jpl.nasa.gov/news/voyager-2-returns-to-normal-operations

ONGOING RESEARCH

End-User Development

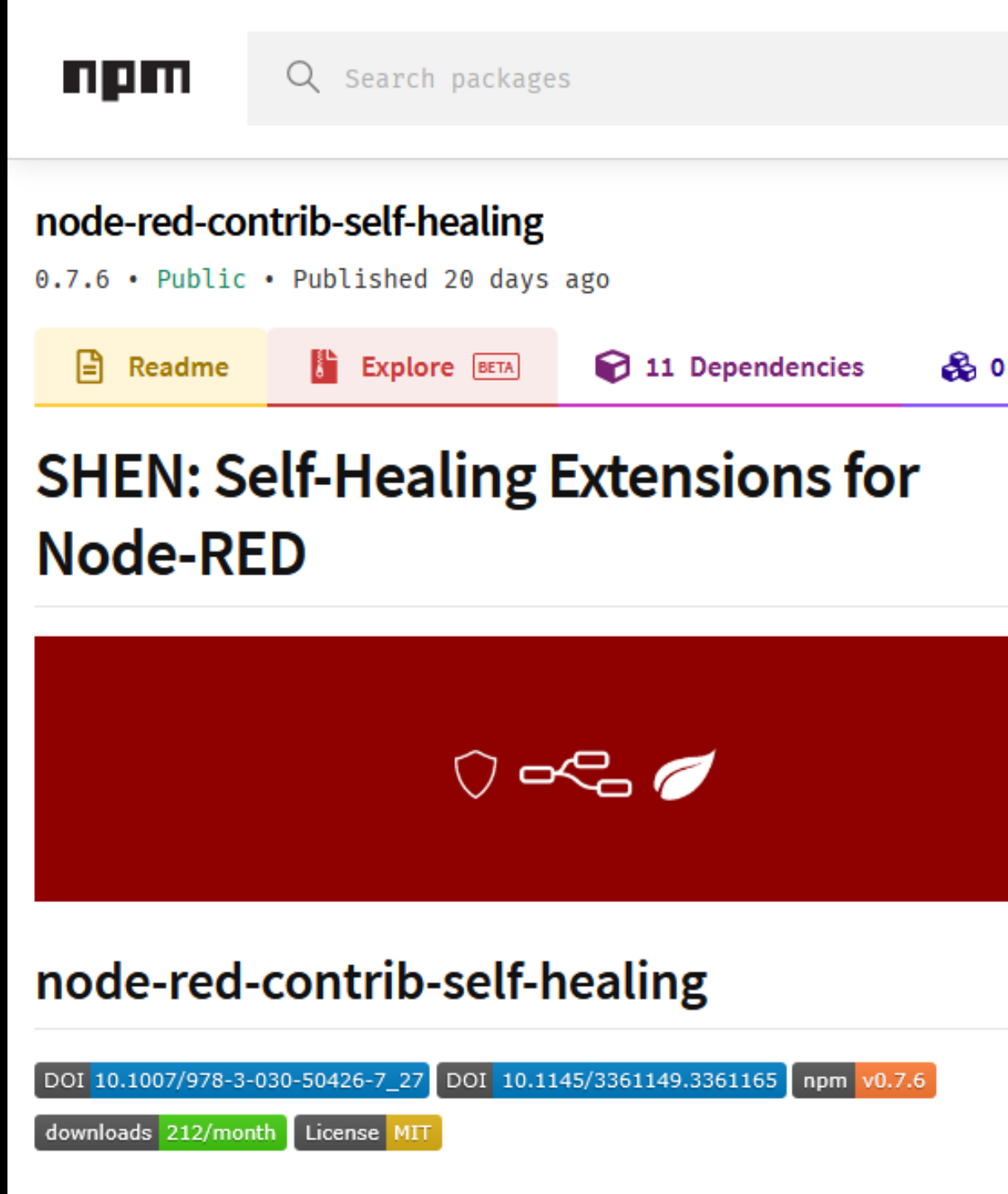


- "Real-time Feedback in Node-RED for IoT Development: An Empirical Study"
  Diogo Torres, João Pedro Dias, André Restivo and Hugo Sereno Ferreira
- "Conversational Interface for Managing Non-Trivial Internet-of-Things Systems"
  André Sousa Lago, João Pedro Dias, and Hugo Sereno Ferreira

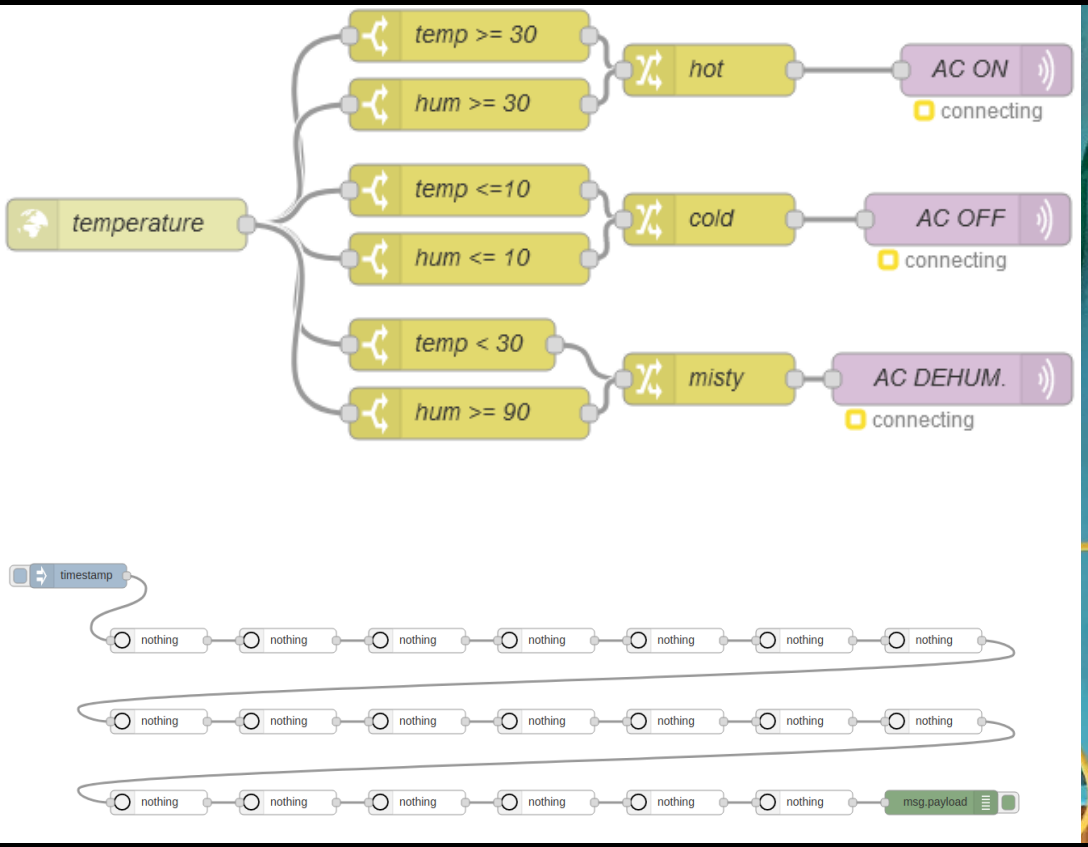
Autonomic Computing

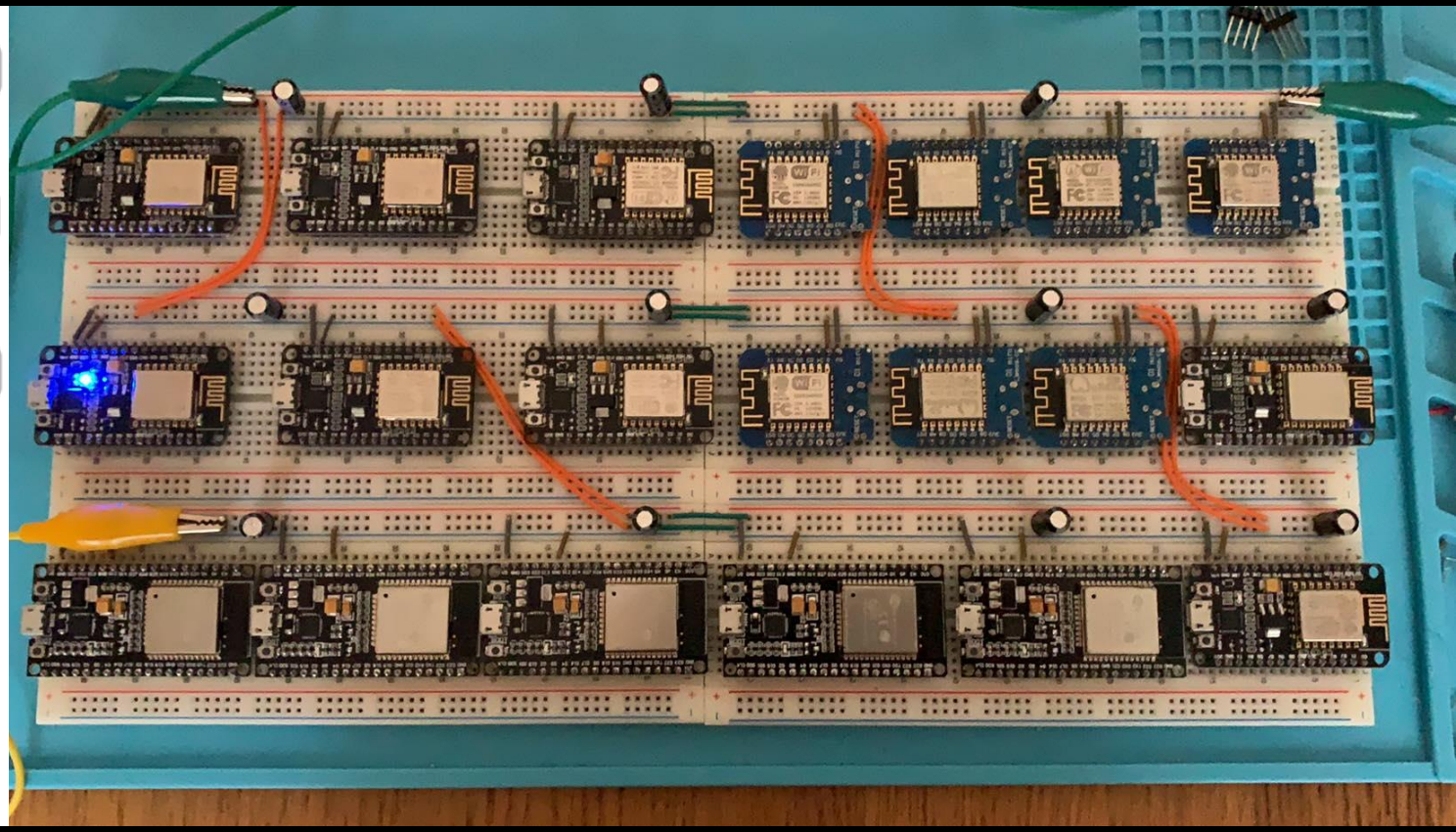
- “A Pattern-Language for Self-Healing Internet-of-Things Systems”
  João Pedro Dias, Tiago Boldt Sousa, André Restivo and Hugo Sereno Ferreira

- “Visual Self-Healing Modelling for Reliable Internet-of-Things Systems”
  João Pedro Dias, Bruno Lima, João Pascoal Faria, André Restivo and Hugo Sereno Ferreira



Distributed IoT Computation

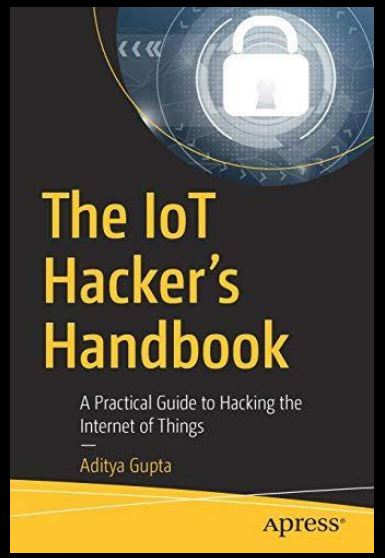


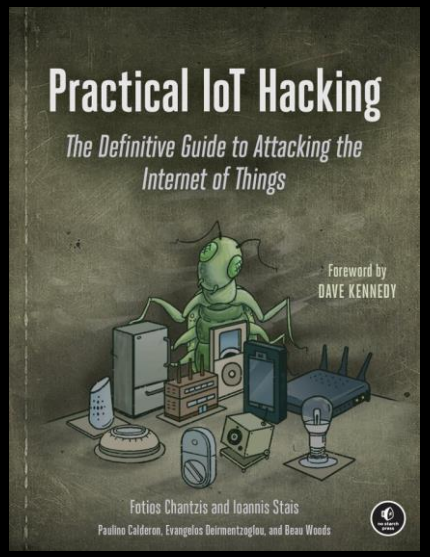


- Visually-defined Real-Time Orchestration of IoT Systems
  Margarida Silva, João Pedro Dias, André Restivo and Hugo Sereno Ferreira

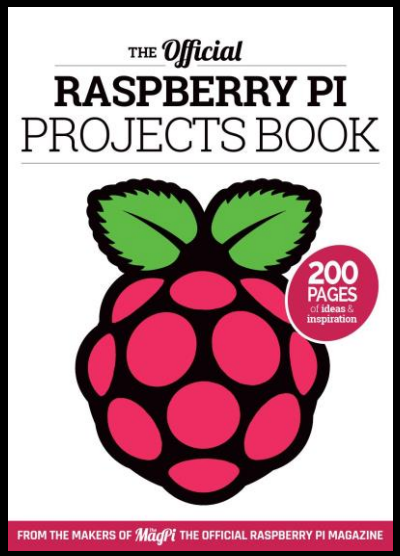
Read More


O'REILLY
Sean Smith
Grayscale Edition
For Sale in the Indian Subcontinent & Select Countries Only
The Internet of Risky Things
Trusting the Devices That Surround Us
SPD


The IoT Hacker's Handbook
A Practical Guide to Hacking the Internet of Things
Aditya Gupta
Apress


Practical IoT Hacking
The Definitive Guide to Attacking the Internet of Things
Foreword by DAVE KENNEDY
Fotios Chantzis and Ioannis Stais
Paulino Calderon, Evangelos Deirmentzoglou, and Beau Woods


IBM Press
IBM
Autonomic Computing
On Demand Series
Richard Murch


THE Official
RASPBERRY PI
PROJECTS BOOK
200 PAGES of ideas & inspiration
FROM THE MAKERS OF MagPi THE OFFICIAL RASPBERRY PI MAGAZINE



http://jpdias.me
jpmdias@fe.up.pt || jpdias@pm.me
@jpd1as